

Design Document using SA/SD Methodology for Website Vulnerability Scanner

Software Engineering Team

September 2025

Contents

1	Data Flow Diagram (DFD) Model	2
1.1	Level 0 DFD	2
1.1.1	Context Diagram	2
1.2	Level 1 DFD	3
1.2.1	Top-Level Functional Decomposition	3
1.3	Level 2 DFDs	4
1.3.1	0.1 User Authentication & Access Control	4
1.3.2	0.2 Target Management & Authorisation	4
1.3.3	0.3 Scan Configuration & Execution	6
1.3.4	0.4 Discovery (Crawling)	6
1.3.5	0.5 Vulnerability Detection	8
1.3.6	0.6 Findings Management	8
1.3.7	0.7 Reporting & Export	10
1.3.8	0.8 Safety, Auditing & Administration	10
2	Core Modules	12
2.1	0.1 User Authentication & Access Control	12
2.2	0.2 Target Management & Authorisation	12
2.3	0.3 Scan Configuration & Execution	12
2.4	0.4 Discovery (Crawling)	12
2.5	0.5 Vulnerability Detection	12
2.6	0.6 Findings Management	12
2.7	0.7 Reporting & Export	13
2.8	0.8 Safety, Auditing & Administration	13
3	Structure Charts	13
3.1	Level 1 Structure Chart	13
3.1.1	Module Decomposition	13

1 Data Flow Diagram (DFD) Model

1.1 Level 0 DFD

1.1.1 Context Diagram

Figure 1 illustrates the Level 0 Context Diagram for the Website Vulnerability Scanner system, defining the central system boundary and its interactions with key external entities including the WVS User, System Administrator, Target Website, Public DNS Resolvers, SMTP Relay, and OSV/EPSS Advisory APIs.

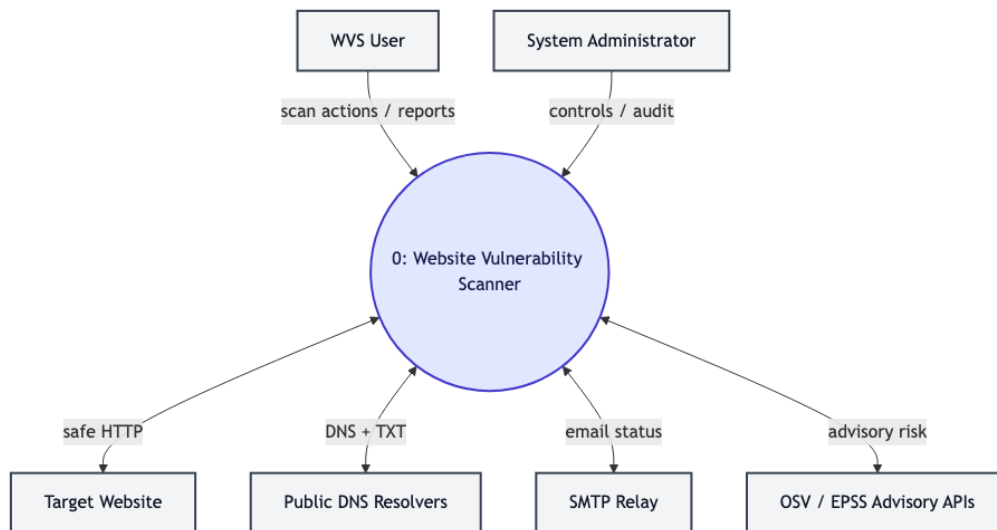


Figure 1: Level 0 Context Diagram

1.2 Level 1 DFD

1.2.1 Top-Level Functional Decomposition

Figure 2 depicts the Level 1 DFD, decomposing the system into 8 primary functional groups (0.1 through 0.8). It displays the primary scanning pipeline from user request to final report generation, alongside the centralized Scope Guard safety controls and third-party API flows.

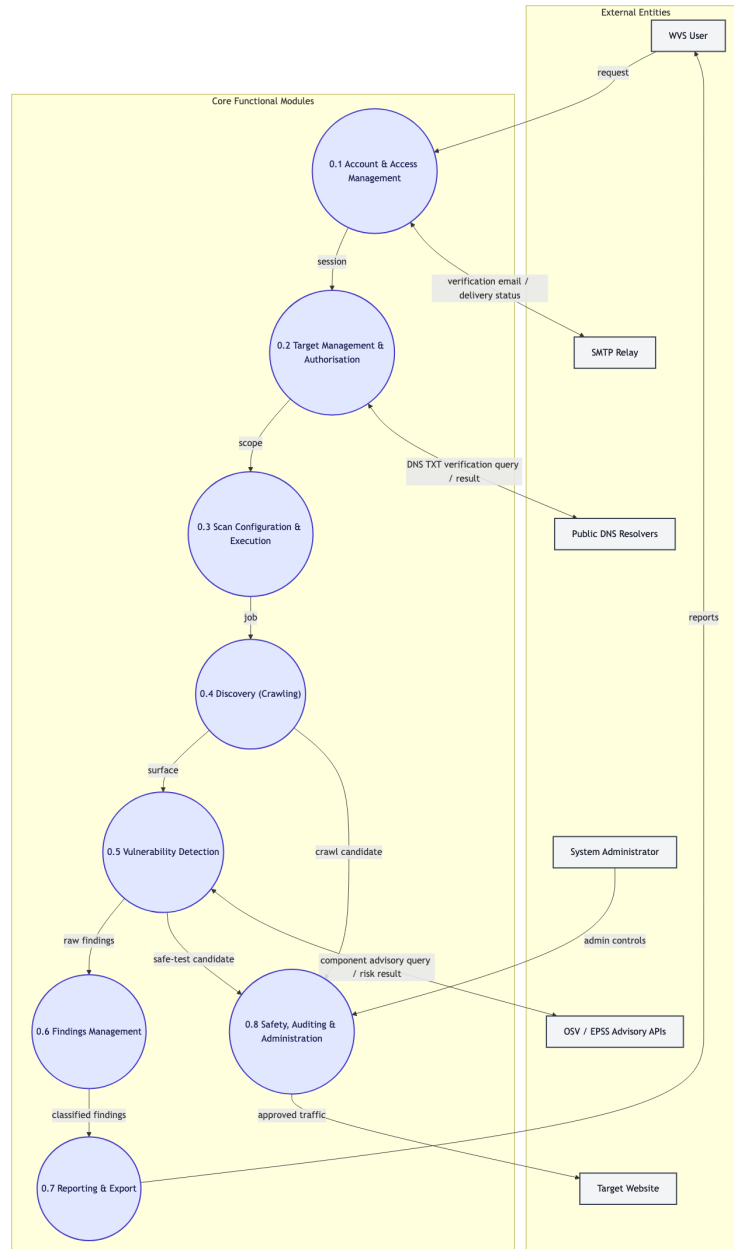


Figure 2: Level 1 DFD with 8 functional groups

1.3 Level 2 DFDs

1.3.1 0.1 User Authentication & Access Control

Figure 3 shows the Level 2 DFD for User Authentication & Access Control (0.1), detailing credential validation, session token issuance, and login audit logging.

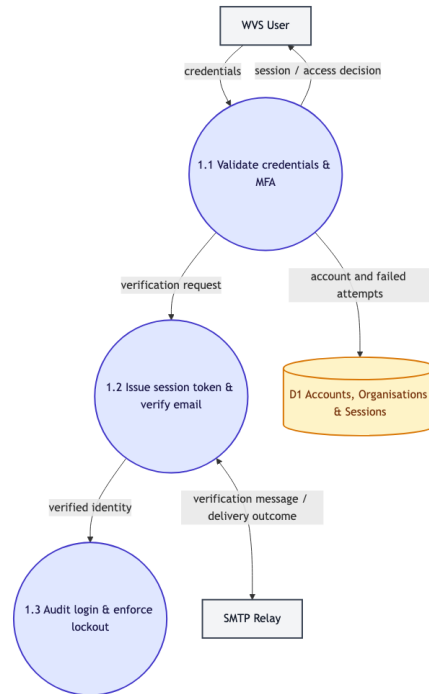


Figure 3: Level 2 DFD for 0.1 User Authentication & Access Control

1.3.2 0.2 Target Management & Authorisation

Figure 4 illustrates the Level 2 DFD for Target Management & Authorisation (0.2), handling target registration, token issuance, and DNS TXT / well-known ownership verification.

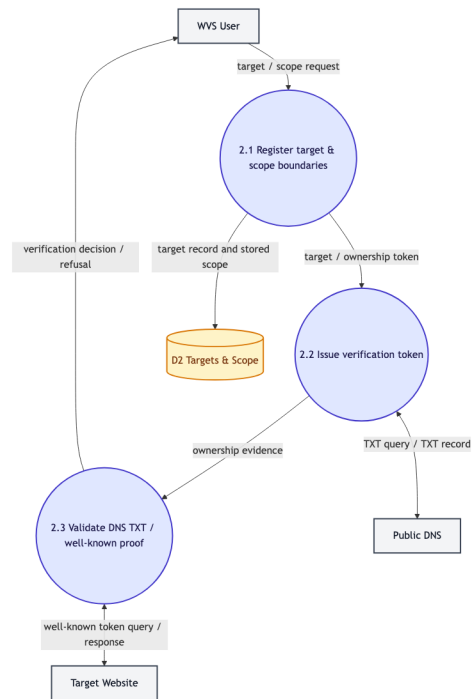


Figure 4: Level 2 DFD for 0.2 Target Management & Authorisation

1.3.3 0.3 Scan Configuration & Execution

Figure 5 illustrates the Level 2 DFD for Scan Configuration and Execution (0.3), depicting profile validation against stored limits, job queuing, and lifecycle execution.

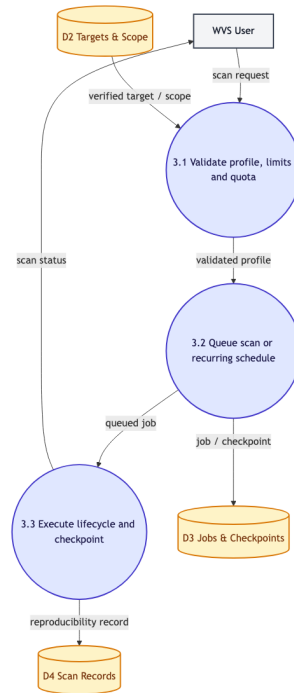


Figure 5: Level 2 DFD for 0.3 Scan Configuration & Execution

1.3.4 0.4 Discovery (Crawling)

Figure 6 shows the Level 2 DFD for Discovery (0.4), showing scope loading, link discovery, and JS rendering deduplication with safe candidate routing to Scope Guard.

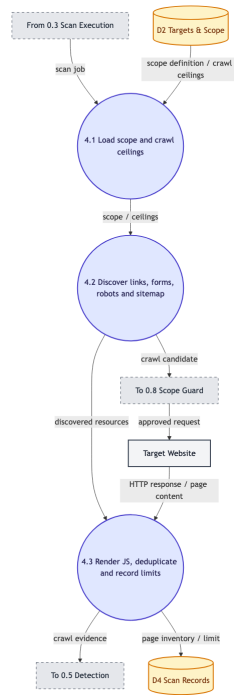


Figure 6: Level 2 DFD for 0.4 Discovery (Crawling)

1.3.5 0.5 Vulnerability Detection

Figure 7 depicts the Level 2 DFD for Vulnerability Detection (0.5), covering passive response checks, active test preparation via Scope Guard, and component advisory version enrichment.

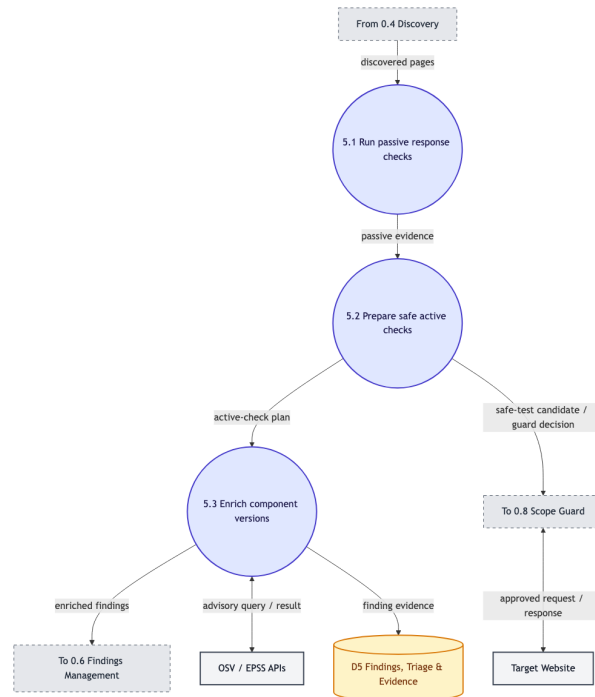


Figure 7: Level 2 DFD for 0.5 Vulnerability Detection

1.3.6 0.6 Findings Management

Figure 8 shows the Level 2 DFD for Findings Management (0.6), outlining normalisation, historical scan comparison, and triage/filtering.

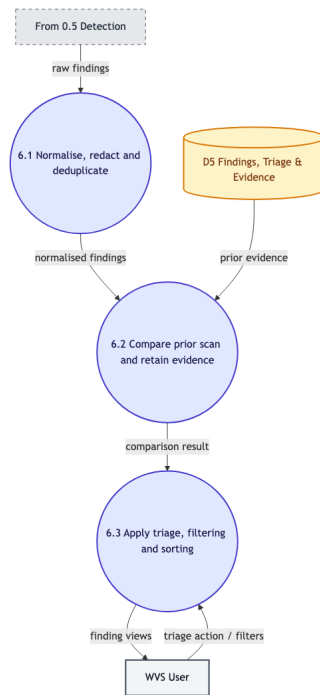


Figure 8: Level 2 DFD for 0.6 Findings Management

1.3.7 0.7 Reporting & Export

Figure 9 illustrates the Level 2 DFD for Reporting and Export (0.7), detailing completed scan selection, report template assembly, and export/notification generation.

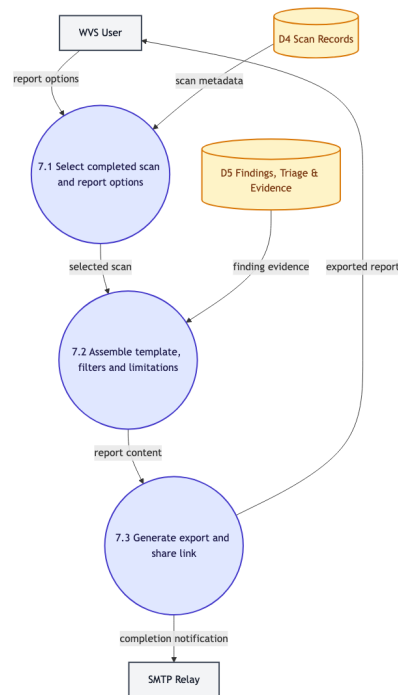


Figure 9: Level 2 DFD for 0.7 Reporting & Export

1.3.8 0.8 Safety, Auditing & Administration

Figure 10 illustrates the Level 2 DFD for Safety, Auditing and Administration (0.8), detailing scope verification, IP re-resolution, rate limiting, and request dispatch with append-only audit logging.

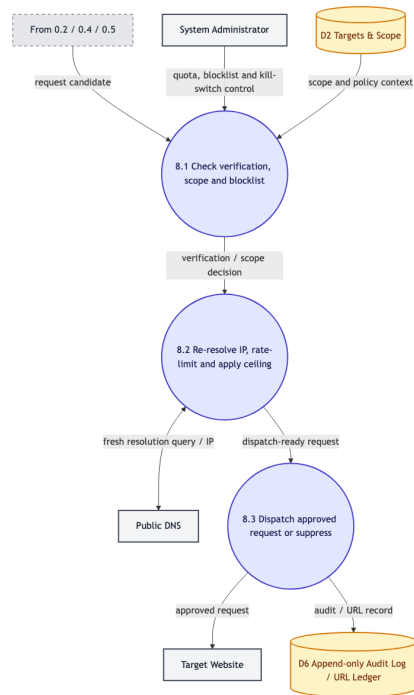


Figure 10: Level 2 DFD for 0.8 Safety, Auditing & Administration

2 Core Modules

This section describes the main modules of the Website Vulnerability Scanner. Each module handles a distinct phase of the scanning lifecycle.

2.1 0.1 User Authentication & Access Control

Handles user authentication, organisation onboarding, session management, and multi-factor verification.

- **Functions:** Register User, Validate Credentials & MFA, Issue Session Token (JWT), Audit Login & Enforce Lockout.

2.2 0.2 Target Management & Authorisation

Manages domain registration, scope definitions, ownership verification tokens, and DNS/well-known target validation.

- **Functions:** Register Target & Scope, Issue Verification Token, Validate DNS TXT / Well-Known Proof, Store Scope Rules.

2.3 0.3 Scan Configuration & Execution

Validates scan profile settings, checks user quotas, queues execution jobs, and manages lifecycle execution checkpoints.

- **Functions:** Validate Profile & Quota, Queue Scan Job / Schedule, Execute Lifecycle & Checkpoint, Record Scan Reproducibility.

2.4 0.4 Discovery (Crawling)

Extracts attack surface elements including links, forms, API endpoints, and dynamic JS content while abiding by crawl ceilings.

- **Functions:** Load Scope & Ceilings, Discover Links & Sitemap, Render JS & Deduplicate, Dispatch Candidates to Scope Guard.

2.5 0.5 Vulnerability Detection

Performs non-destructive vulnerability checks, passive header analysis, active payload testing via Scope Guard, and advisory database lookup.

- **Functions:** Run Passive Response Checks, Prepare Safe Active Checks, Enrich Component Versions via OSV/EPSS APIs.

2.6 0.6 Findings Management

Normalises raw scan evidence, redacts sensitive tokens, correlates findings against prior scan runs, and applies triage filters.

- **Functions:** Normalise & Redact Findings, Compare Prior Scan Evidence, Apply Triage, Filtering & Severity Sorting.

2.7 0.7 Reporting & Export

Assembles executive and technical report documents, formats exports (PDF/CSV), and dispatches completion notifications.

- **Functions:** Select Completed Scan, Assemble Report Template & Evidence, Generate Export / Share Link, Send SMTP Notification.

2.8 0.8 Safety, Auditing & Administration

Enforces safety invariants, validates target scope, re-resolves DNS to prevent TOCTOU/SSRF attacks, applies rate limits, and maintains an append-only URL ledger.

- **Functions:** Check Verification & Scope Blocklist, Re-resolve IP & Rate-Limit, Dispatch Approved Request, Append Audit Log.

3 Structure Charts

3.1 Level 1 Structure Chart

3.1.1 Module Decomposition

The system module hierarchy follows a structured top-down functional decomposition, decoupling user interface and management services from the core crawling engine, detection modules, and centralized Scope Guard safety layer.